

A photograph of a modern university building with large glass windows and a white facade. In the foreground, there is a field of tall grass and yellow wildflowers. A semi-transparent white box is overlaid on the left side of the image, containing the course title and week information.

5CM512 Communication and Security Protocols

Week 12 : HTTPs

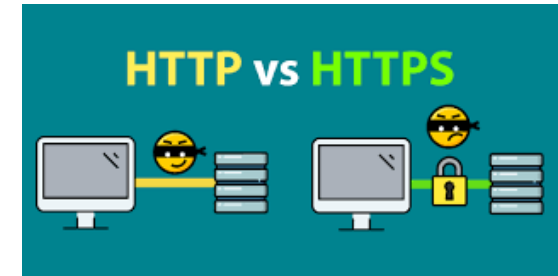
HTTPS

(HTTP over SSL)

- Combination of HTTP and SSL



- Secure communication between a Web browser and a Web server
- Built into all modern Web browsers
 - URL addresses that begin with **https://** rather than **http://**



- HTTPS → port 443
 - invokes SSL



- Documented in RFC 2818, HTTP Over TLS
 - No fundamental change in using HTTP over either SSL or TLS
 - both implementations are referred to as HTTPS



Class discussion

- _____
- _____
- _____

HTTPS (HTTP over SSL)

- Encrypted elements of communication:

- URL of the requested document



- Contents of the document



- Contents of browser forms



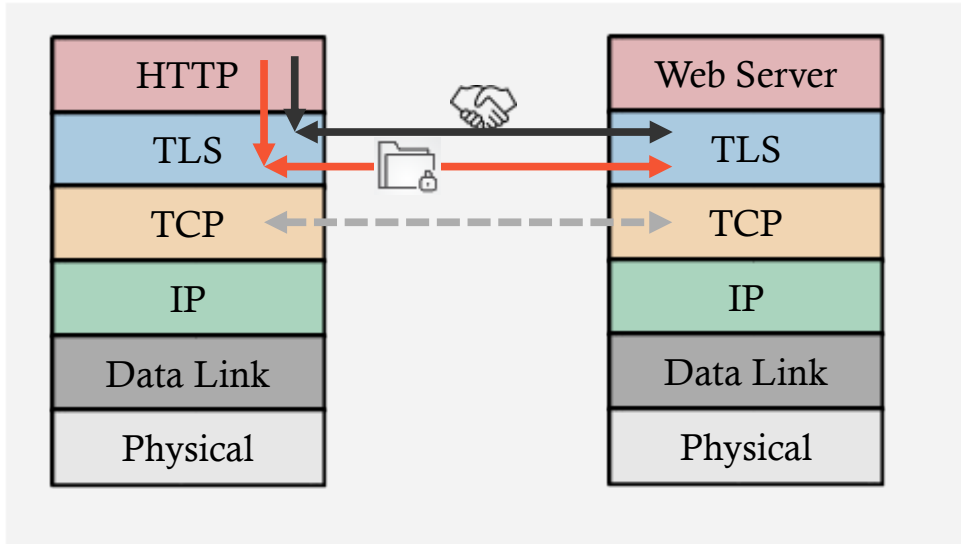
- Cookies sent from browser to server and from server to browser



- Contents of HTTP header



Connection Initiation



- HTTPS client
 - HTTP + TLS
 - Initiate a connection
- TLS
 - Handshake (session)
 - Connections
- HTTP
 - Send requests over TLS

Connection Closure

- An HTTP client or server can close a connection

- `Connection: close`



- Closure of an HTTPS connection

- TLS close the connection with the peer TLS entity on the remote side

- Closing the underlying TCP connection

- TLS implementations must initiate an exchange of closure alerts before closing a connection
 - A TLS implementation may, after sending a closure alert, close the connection without waiting for the peer to send its closure alert, generating an “incomplete close”
- An unannounced TCP closure could be evidence of some sort of attack so the HTTPS client should issue some sort of security warning when this occurs

Secure Shell (SSH)

A protocol for secure network communications

Simple and inexpensive to implement



SSH client and server applications are widely available for most operating systems

- Has become the method of choice for remote login and X tunneling
- Is rapidly becoming one of the most pervasive applications for encryption technology outside of embedded systems



SSH1

Providing a secure remote logon facility

Replacing TELNET and other remote logon schemes that provided no security

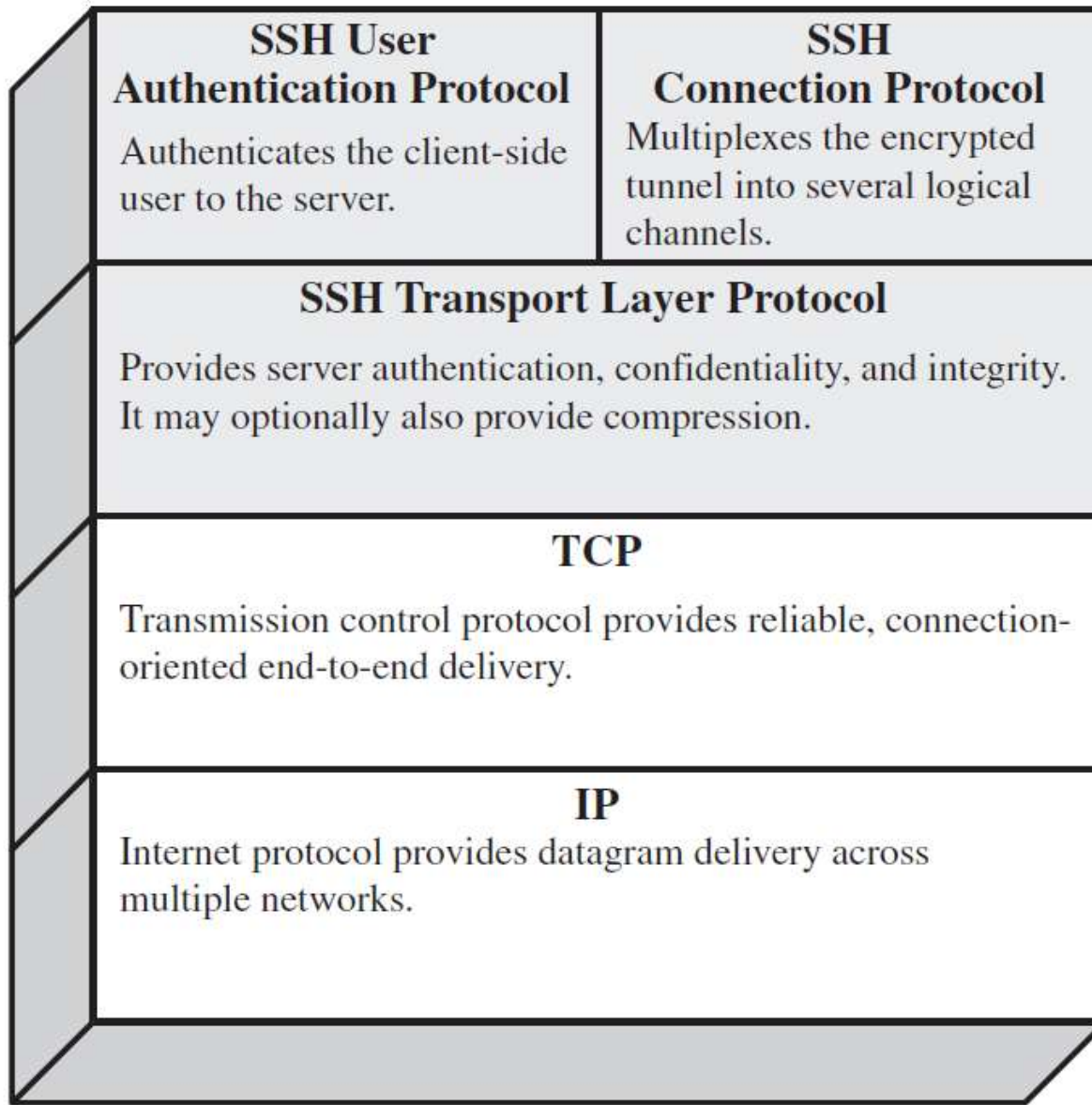


Provides a more general client/server capability

- Used for such network functions as file transfer and e-mail

SSH2

fixes a number of security flaws

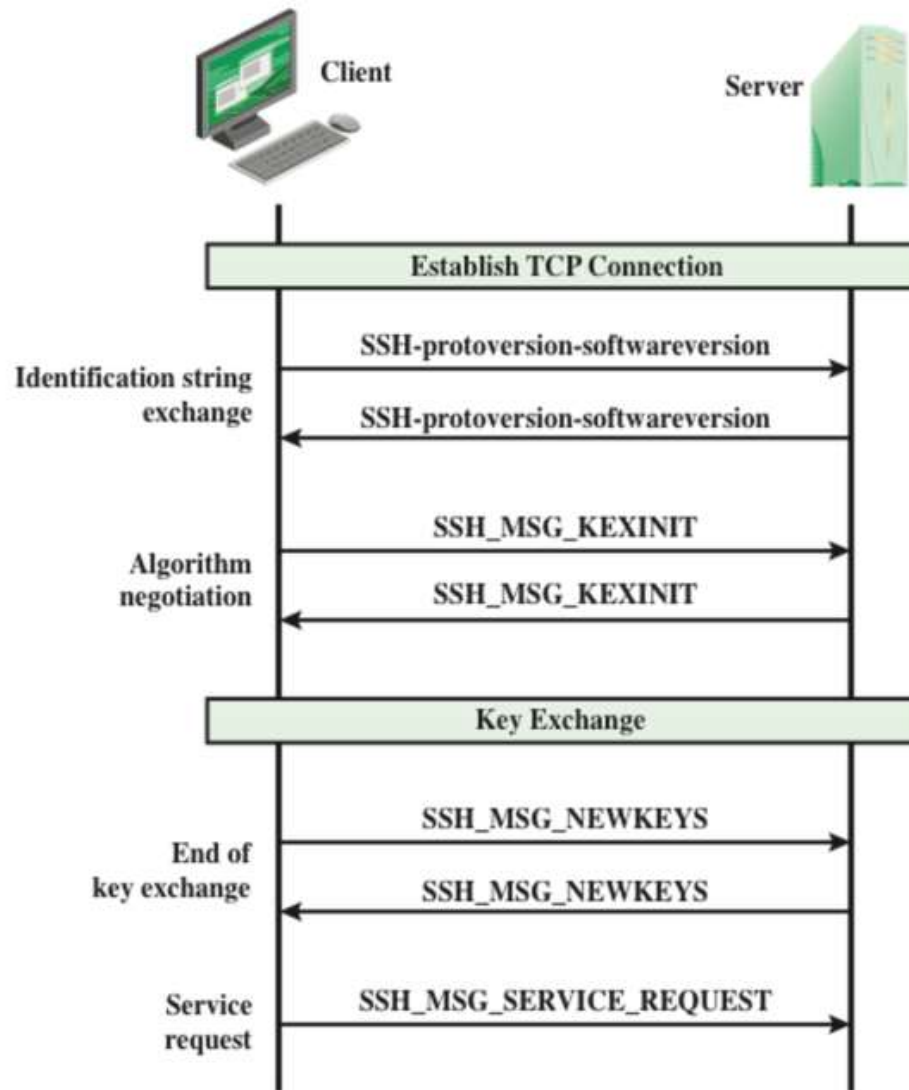


SSH Protocol Stack

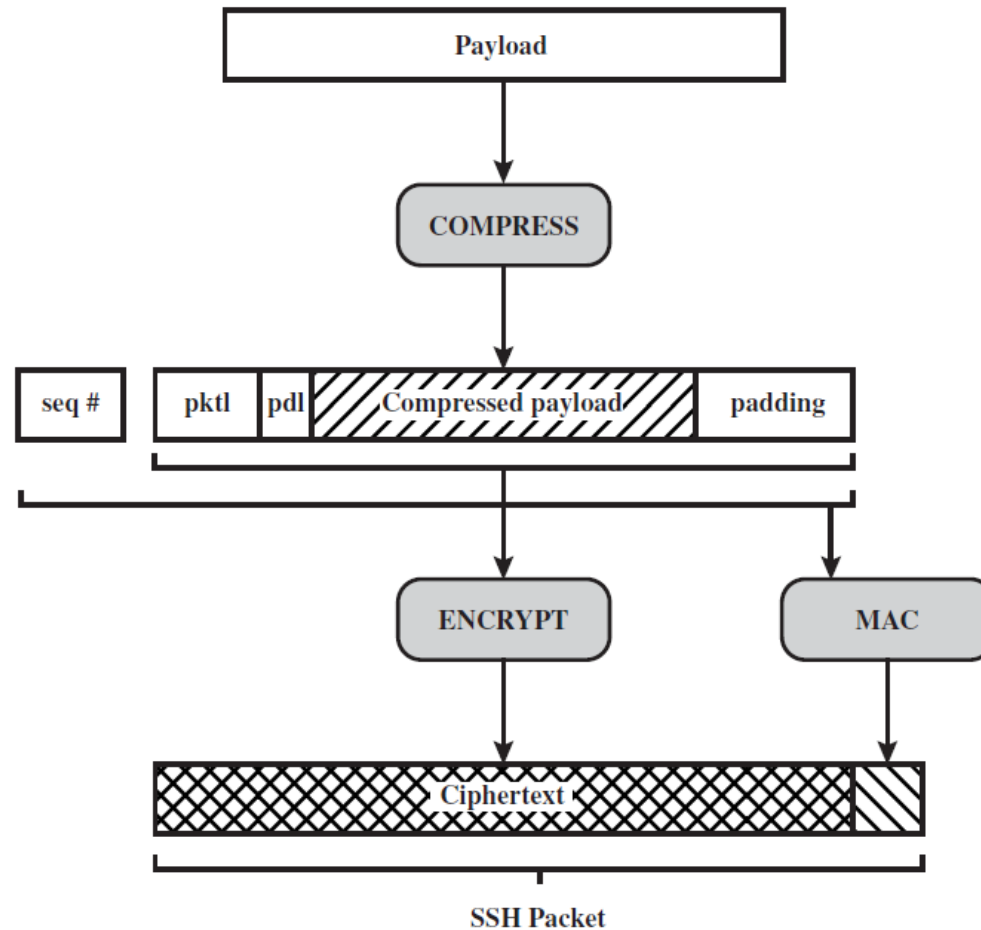
Transport Layer Protocol

- Server authentication occurs at the transport layer
 - based on the server possessing a public/private key pair
- Server
 - multiple host keys
 - using multiple different asymmetric encryption algorithms
- Multiple hosts may share the same host key
- The **server host key** is used during key exchange to authenticate the identity of the host
- Two alternative trust models:
 - The client has a local database that associates each host name with the corresponding public host key
 - The host name-to-key association is certified by a trusted certification authority (CA);
 - the client only knows the CA root key and can verify the validity of all host keys certified by accepted CAs

SSH Transport Layer Protocol Packet Exchanges



SSH Transport Layer Protocol Packet Formation



pktl = packet length
pdl = padding length

Cipher	
3des-cbc*	Three-key 3DES in CBC mode
blowfish-cbc	Blowfish in CBC mode
twofish256-cbc	Twofish in CBC mode with a 256-bit key
twofish192-cbc	Twofish with a 192-bit key
twofish128-cbc	Twofish with a 128-bit key
aes256-cbc	AES in CBC mode with a 256-bit key
aes192-cbc	AES with a 192-bit key
aes128-cbc**	AES with a 128-bit key
Serpent256-cbc	Serpent in CBC mode with a 256-bit key
Serpent192-cbc	Serpent with a 192-bit key
Serpent128-cbc	Serpent with a 128-bit key
arcfour	RC4 with a 128-bit key
cast128-cbc	CAST-128 in CBC mode

* = Required

** = Recommended

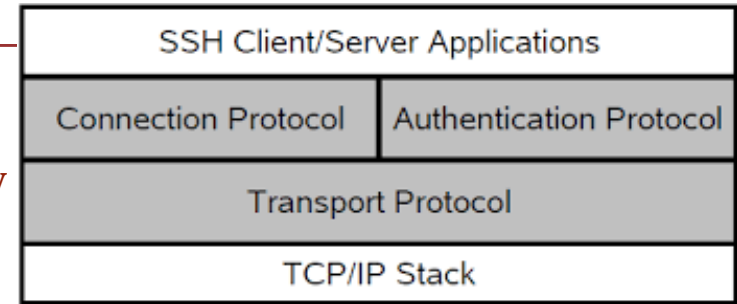
MAC algorithm	
hmac-sha1*	HMAC-SHA1; digest length = key length = 20
hmac-sha1-96**	First 96 bits of HMAC-SHA1; digest length = 12; key length = 20
hmac-md5	HMAC-SHA1; digest length = key length = 16
hmac-md5-96	First 96 bits of HMAC-SHA1; digest length = 12; key length = 16

Compression algorithm	
none*	No compression
zlib	Defined in RFC 1950 and RFC 1951

Authentication Methods

Publickey

- Client → Server :
 - Client's public key, Signed by the client's private key
- Server : Checks
 - Whether the key is acceptable for authentication
 - Whether the signature is correct



Password

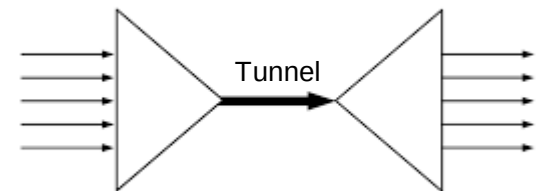
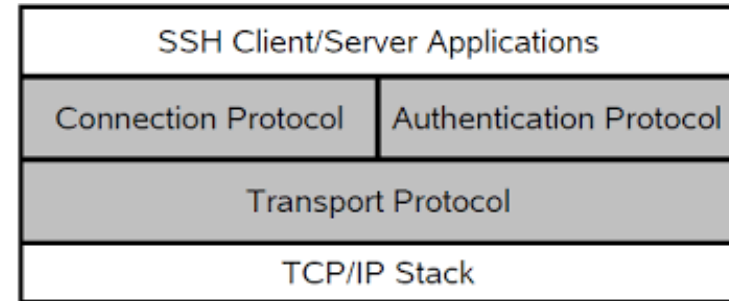
- Client → Server :
 - Plaintext password ; protected by encryption by the Transport Layer Protocol

Hostbased

- Authentication is performed on the client's host
- Client → Server :
 - Signature ; created with the private key of the client host
- Server :
 - verifies the identity of the client host

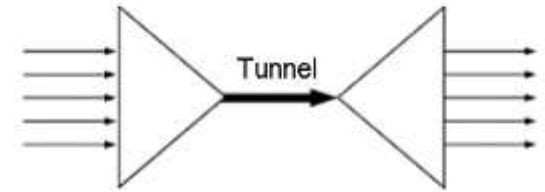
Connection Protocol

- The SSH Connection Protocol
 - runs on top of the SSH Transport Layer Protocol
 - assumes that a secure authentication connection is in use
 - The secure authentication connection
 - referred to as a *tunnel*
 - used by the Connection Protocol to multiplex a number of logical channels

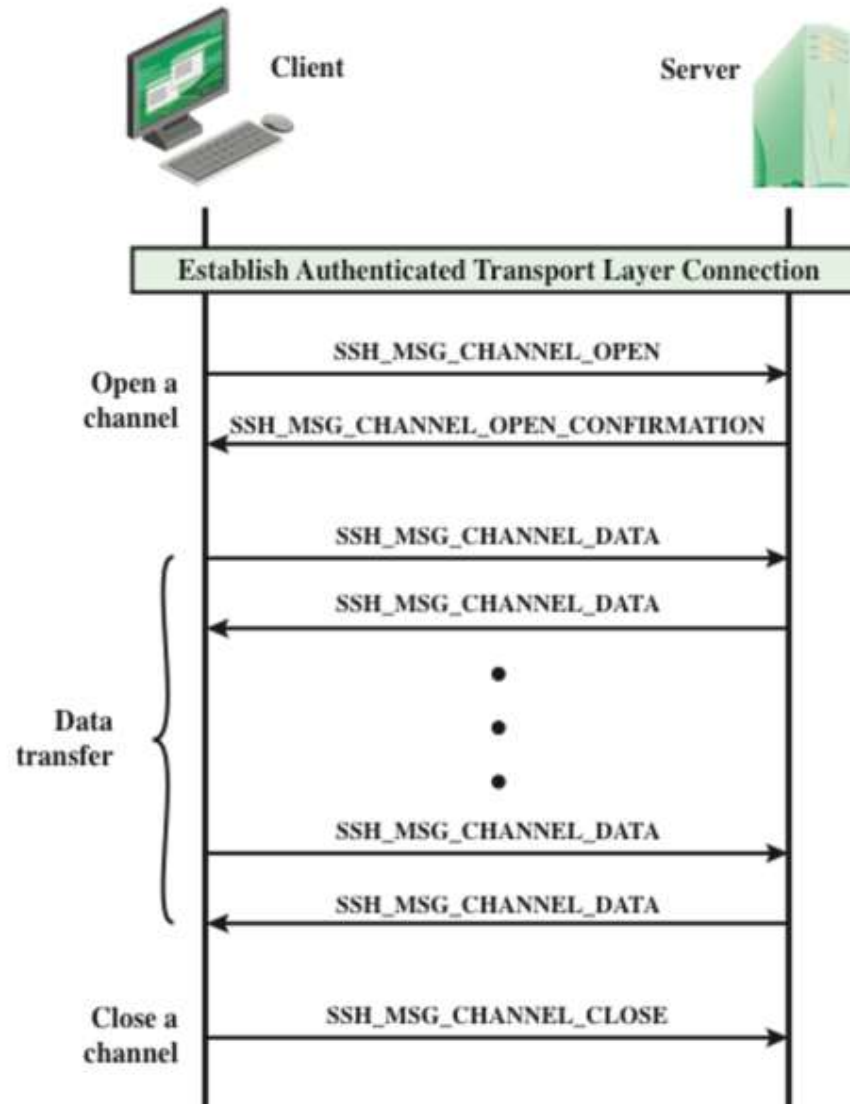


Connection Protocol

- Channel mechanism
 - All types of communication using SSH
 - supported using separate channels
 - Either side may open a channel
 - Unique channel number
 - Channels are flow controlled
 - using a window mechanism
 - No data may be sent to a channel until a message is received to indicate that window space is available
 - The life of a channel : Three stages
 - opening a channel,
 - data transfer
 - closing a channel



Example SSH Connection Protocol Message Exchange



Any QUESTIONS?

